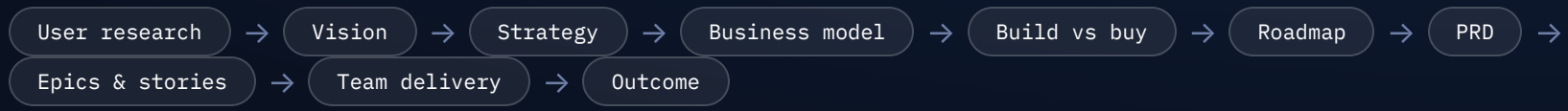
Platform, Portal & Trust

The product nobody sees and everybody depends on: sign-in, roles, tenant isolation and an audit trail. Every other product in this portfolio assumes this one is already trustworthy.

Sherif Hilal
Product · OVARC

Theme T8
Initiative · Trust goal

Release R1 foundation
Nov 2026 – May 2027 (example)



All names, dates, figures and tools are illustrative examples built on the OVARC case study.

VISION & NORTH STAR

VISION

Every company in Egypt pays its people right, on time, with no spreadsheets.

For Platform: the platform is trusted with payroll data before a single client record touches it.

NORTH STAR (COMPANY-WIDE)

Clean payroll closes per month

Companies that close monthly payroll on OVARC on time with zero manual corrections afterwards.

WHAT THIS MUST NOT BREAK

A single cross-tenant data leak ends trust in every other product this company builds. Every release is blocked by a leak test, with no exceptions.

THIS PRODUCT'S OWN KEY RESULTS

Before pilot
PDPL licence secured

100%
of modules behind role-based access

RTL
Arabic on every screen, by default

Half a day of manual setup per client; payroll errors traced to retyped tax IDs; password resets top the queue.
U5 · Support tickets and onboarding ops, last quarter's tickets, strength 3

STRATEGY CASCADE (PLAYING TO WIN)

Every choice here traces to evidence (U = user research, M = market research) and down to canvas items. Platform is the one initiative every other initiative is built on top of.

WHERE TO PLAY	**W3** Egypt first; Saudi Arabia and the UAE later (data region chosen per client)	KP4 VP5
HOW TO WIN	**H2** Arabic-first and phone-first for employees	VP4 CR2 CS3
CAPABILITIES	**C3** Trusted, compliant platform	KR4 KA4 CO4
MANAGEMENT	**MS** North star and supporting metrics, monthly roadmap review, release exit criteria	VP1

Labour Law No. 14 of 2025, Social Insurance Law No. 148 of 2019 and Data Protection Law No. 151 of 2020 make payroll complex and regulated, and change over time.
M1 · Law and regulation, public laws, strength 3 (confirmed by legal counsel)

WHERE IT SITS IN THE BUSINESS MODEL

The canvas items this product delivers or depends on, colour-coded by confidence. A full 9-block canvas is in the Business view; this is this product's slice of it.

VP5
Data kept safe and legal

KR4
A trusted multi-company platform

KA4
Build and secure the platform

CO4
Compliance: data-protection licence, pen tests, audits

KP4
In-region cloud hosting and identity provider

CO3
Usage costs: cloud, SMS, e-signature

Validated · Partly backed · Assumption

WHY THIS PRODUCT, AND WHY NOW

It's in the Now lane for a reason: no employee record, no payroll run and no leave request can exist until a tenant, its roles and its audit trail exist. The expansion bet (W3, Saudi Arabia and the UAE later) also depends on data residency being a platform decision, not a per-feature afterthought.

BUILD VS BUY DECISIONS

Every dependency got one explicit call before design started: buy what's a commodity, build what's the product. These decisions sit in the technical decision map and the sprint dependency list.

Identity and sign-in (OIDC) — BUY

"Buy an OIDC identity provider; don't store passwords ourselves." Authentication is not where OVARC differentiates, and getting it wrong is a trust risk, not a feature.

Decision card x1 · capability C3

Tenant isolation (row-level security) — BUILD

The actual trust guarantee a client is buying: their competitor's payroll data must never be reachable from their account. Specific to our multi-tenant model, tested on every build.

NFR Isolation · KR4

Immutable audit log — BUILD

Who changed a salary, a bank detail or a role, and when — kept 5 years, pending legal confirmation. This is OVARC's answer to an auditor, and it has to be ours.

NFR Audit · story OV-103

Penetration testing — BUY

Specialist, adversarial testing bought from a vendor before beta and each major release, rather than attempted in-house.

Dependency: pen-test vendor

> *The rule: if it's identity or security infrastructure that a specialist genuinely does better, buy it. If it's the isolation guarantee a client is trusting us with — that their data never touches a competitor's — that's ours to build and prove on every single build, not just at launch.*

ROADMAP, CONNECTED BACK TO THE STRATEGY

Platform ships almost entirely before any client-facing feature, then returns twice more: once for enterprise sign-in, once for the employee-facing portal.



WHY FOUNDATION-FIRST

Nothing else can be audited, isolated or role-checked without this. It's the only initiative that ships before any pilot client record exists.

WHAT WE DELIBERATELY DEFERRED

A custom role builder and the asset register move to Later — no pilot has asked for either yet, and building them now would be solving a problem nobody has confirmed.

PRD — PROBLEM, USERS, SCOPE, NFRS

PROBLEM

Payroll data is the most sensitive data a company holds. Without tenant isolation, roles and an audit trail, no client should trust OVARC with it, and nothing else can be built safely.

USERS

Nour, HR lead — an admin role with MFA required
Karim, Finance manager — a payroll-approver role
Heba, OVARC ops — sets up each new client tenant
Ahmed, Employee — the lowest-privilege, self-service-only role

OBJECTIVE AND KEY RESULTS

The platform is trusted with payroll data: PDPL licence before pilot data, role-based access on every module, Arabic RTL on every screen.

In scope

- Login with MFA and company SSO
- Roles and permissions per module
- Tenant isolation
- Immutable audit log
- Employee portal shell

Out of scope (this release)

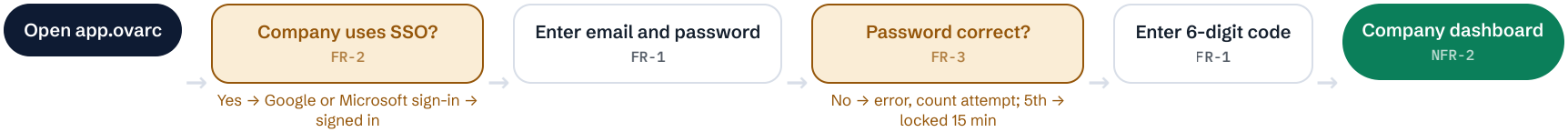
- Attendance and biometrics
- Custom role builder (Later)

NON-FUNCTIONAL REQUIREMENTS

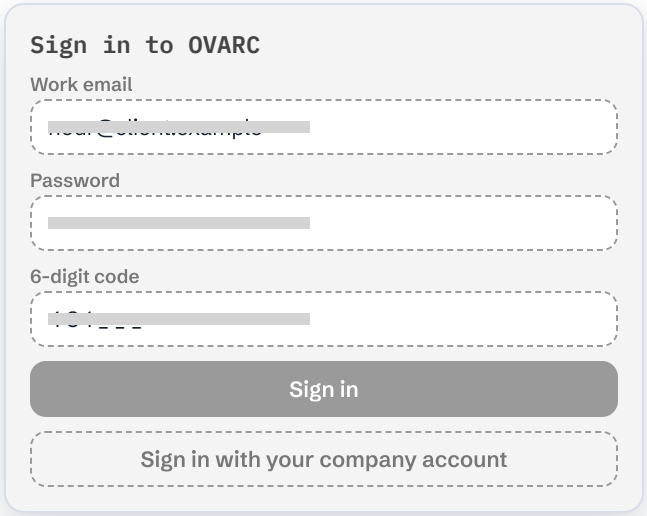
Security	MFA for admins; OWASP Top 10 covered; pen test before beta
Isolation	Row-level security on every tenant table; a leak test runs in CI
Audit	Every sensitive action logged, immutable, kept 5 years (to confirm with legal)
Availability	99.9% monthly for login and API
Localisation	Arabic and English, RTL layout on every screen

The first screen every user meets, and the one that decides whether a client trusts OVARC with payroll data at all. Below is its user flow, then the same screen from its first grey wireframe to the version tested with 5 HR users.

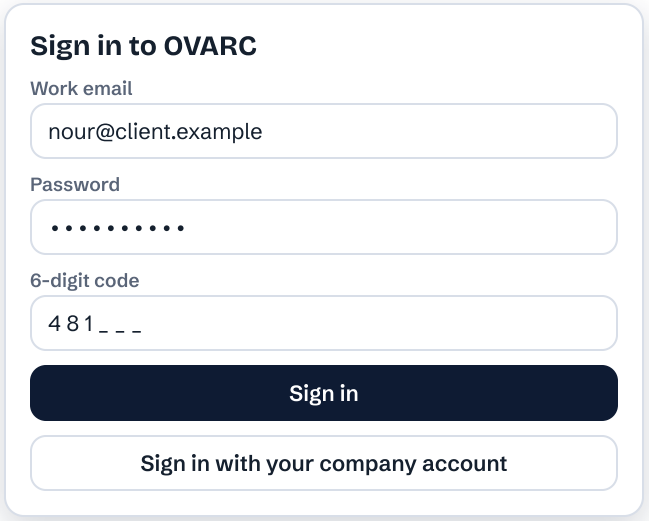
USER FLOW · OV-101 SIGN IN WITH MFA OR COMPANY SSO, FOR NOUR, HR MANAGER



WIREFRAME · LOW FIDELITY



FINAL UI · TESTED WITH USERS



WHAT CHANGED FROM WIREFRAME TO FINAL

- 3 of 5 users looked for the code before the password step finished — code now has its own step, labelled Step 2 of 2
- 2 of 5 missed the company sign-in button at the bottom — moved it above the password field, not hidden in a menu
- Arabic users didn't understand the lock message — copy now says exactly when they can try again

USABILITY TEST

5 / 5 completed the task, median **38 s**, with 5 HR users, remote, 30 minutes each. Every one of these fixes came from a 30-minute session, not a guess — this is the trust layer, so nothing here ships on instinct.

EPICS → USER STORIES

E24
Roles, permissions and audit log
21 PTS · R1

E23
Employee self-service portal
8 PTS · R4

E22
Asset register and assignment
M PTS · LATER

THE CORE ACCESS STORIES, EACH WITH ITS OWN CLEAR TEST

ID	STORY	PTS	RELEASE
OV-101	Sign in with MFA or company SSO	8	R1
OV-102	Roles and permissions per module	8	R1
OV-103	Audit log of sensitive actions	5	R1

Given an admin account with MFA enabled

When they enter a correct password and a valid code

Then they land on their company's dashboard within 2 seconds

DEFINITION OF READY, CHECKED

Independent · Negotiable · Valuable · Estimable · ≤ 8 points · Testable AC · Design linked · Deps clear

REQUIREMENTS MATRIX: QUALITY BARS × FEATURES × DESIGN

For OV-101 Sign in with MFA or company SSO: every non-functional requirement (rows) is linked to the functional requirements it constrains (dots), to the test or metric that proves it, and to the design element that delivers it. An empty row or column is a gap, fixed before design starts.

ID	QUALITY BAR	TARGET	FR-1 Email, password and a one-time code	FR-2 Company Google or Microsoft sign-in (SSO)	FR-3 Lock the account after repeated failures	FR-4 Reset password by email link	HOW WE MEASURE IT	WHERE IT SHOWS IN THE DESIGN
NFR-1	**Security**	MFA required for every payroll role	●	●	○	○	Share of admin accounts with MFA on. Target and result: 100%	Code gets its own step, "Step 2 of 2"
NFR-2	**Performance**	Dashboard visible within 2 s of sign-in	●	●	○	○	p95 sign-in to dashboard time in a synthetic test	Button spinner; disabled until fields are valid
NFR-3	**Accessibility**	WCAG 2.1 AA; code field works with phone autofill	●	○	○	●	Automated accessibility scan in CI plus a screen-reader AC	One-tap code autofill, labelled fields
NFR-4	**Localisation**	Arabic right-to-left and English	●	●	●	●	RTL visual check on every screen; every label translated	Mirrored RTL layout, clear Arabic lock message
NFR-5	**Security**	Max 5 attempts per 10 minutes	○	○	●	○	Automated test: the 6th attempt locks the account for 15 minutes	Error banner says exactly when to retry

● Bar applies to this feature Measured by QA / monitoring Delivered in the design

HOW THE TEAMS BUILT THIS TOGETHER

One release, six roles — legal counsel is in the room from refinement, not called in at the end to review a finished feature.

	REFINEMENT	SECURITY REVIEW	DESIGN REVIEW	BUILD & PEN-TEST	BETA
Sherif · PM	Walks PRD, prioritises E24	—	—	—	Reads pilot trust signals
Tech lead	Brings the isolation design	Owns the row-level security tests	—	Triages pen-test findings	—
Legal counsel	—	Confirms PDPL licence scope	—	—	Signs off the retention policy
Designer	—	—	Role-aware UI states, RTL	—	—
Dev	—	—	—	Builds OV-101/102/103	—
Salma · QA	Three amigos on access rules	Leak test added to CI	Testability review	CI gates + pen-test triage	Beta sign-off evidence

> *The leak test runs on every build, not every release — legal counsel and the tech lead agreed before coding started that isolation is the one thing that blocks a merge, no exceptions.*

OUTCOME & WHAT I'D TAKE FORWARD

0
cross-tenant leaks found (CI leak test, ongoing)

100%
admin accounts with MFA enabled

< 30 days
to PDPL licence, per legal's plan

5 yrs
audit log retention (pending legal confirmation)

REFLECTION

This is the page I'd show if someone asked whether I take security seriously as a PM rather than leaving it to engineering. Buying identity and pen-testing wasn't a cost-saving call, it was a competence call: a specialist vendor does both better than we would in year one. Building isolation and the audit log ourselves was the opposite call, for the opposite reason — it's the actual promise we're selling, and no one else can make it for us.

— Sherif Hilal, Product